

Manual de Segurança da Informação

Do básico ao avançado — fundamentos, ataque, defesa e governança

Vitor Mattos

30/07/2026

Índice

Apresentação	1
Para quem é este manual	1
Como o manual está organizado	1
Seções fixas de cada capítulo	3
Política editorial	3
Licença	3
I. Volume 1 — Fundamentos da Segurança da Informação	5
1. O que é segurança da informação	7
1.1. Uma definição de trabalho	7
1.2. Dado, informação e ativo: o que exatamente se protege	8
1.3. Segurança não é um estado, é um processo	9
1.4. Pessoas, processos e tecnologia	10
1.5. O adversário não é só o hacker	10
1.6. Quem ataca, e por que o pequeno também é alvo	11
1.7. Os princípios que sustentam qualquer defesa	12
1.8. O vocabulário mínimo	13
1.9. Como se sabe se está funcionando	13
1.10. Brasil em Foco	14
1.11. No Campo	15
1.12. Resumo	16
2. Os pilares: confidencialidade, integridade e disponibilidade	17
3. Autenticidade, não repúdio e responsabilização	19
4. Ativos, ameaças, vulnerabilidades e risco	21
5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases	23
6. Gestão de risco: análise qualitativa e quantitativa	25
7. Ética, legalidade e a fronteira do escopo autorizado	27
II. Volume 2 — Redes e Sistemas: a Base Técnica	29
8. A pilha TCP/IP sob a ótica do atacante e do defensor	31
9. Endereçamento, roteamento e NAT	33
10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP	35
11. Fundamentos de sistemas operacionais: processos, permissões e memória	37

12. Linux essencial para segurança	39
13. Windows e Active Directory essencial	41
14. Virtualização e montagem do laboratório de estudos	43
 III. Volume 3 — Criptografia Aplicada	 45
15. História e princípios da criptografia	47
16. Criptografia simétrica: AES, modos de operação e AEAD	49
17. Funções hash, HMAC e integridade	51
18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas	53
19. PKI, certificados digitais e cadeias de confiança	55
20. TLS na prática: handshake, versões e configuração segura	57
21. Erros clássicos: criptografia mal empregada	59
 IV. Volume 4 — Identidade, Autenticação e Controle de Acesso	 61
22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC	63
23. Senhas: armazenamento, políticas e ataques	65
24. Autenticação multifator e fatores de autenticação	67
25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect	69
26. Gestão de identidades e de acessos privilegiados (IAM e PAM)	71
27. Arquitetura Zero Trust	73
 V. Volume 5 — Segurança de Redes	 75
28. Arquitetura segura e segmentação de redes	77
29. Firewalls: tipos, políticas e boas práticas	79
30. VPNs: IPsec, WireGuard e acesso remoto seguro	81
31. IDS, IPS e detecção em rede	83
32. Segurança de DNS: ataques, DNSSEC e DoH	85
33. Segurança do roteamento e BGP: sequestros, vazamentos e RPKI	87
34. Segurança em redes sem fio e enlaces de rádio	89
35. Ataques de negação de serviço e estratégias de mitigação	91

VI. Volume 6 — Endpoints e Sistemas Operacionais	93
36. Hardening de servidores Linux	95
37. Hardening de Windows e Active Directory	97
38. Antivírus, EDR e XDR	99
39. Gestão de vulnerabilidades e ciclo de patches	101
40. Segurança de dispositivos móveis e BYOD	103
41. Criptografia de disco e proteção de dados em repouso	105
VII. Volume 7 — Segurança de Aplicações	107
42. Ciclo de desenvolvimento seguro e DevSecOps	109
43. OWASP Top 10: panorama e como usar	111
44. Injeção: SQL, NoSQL e comandos de sistema	113
45. Cross-site scripting e ataques no lado do cliente	115
46. Falhas de autenticação e gestão de sessão	117
47. Falhas de controle de acesso: IDOR, SSRF e escalonamento	119
48. Segurança de APIs REST e GraphQL	121
49. SAST, DAST, SCA e automação de testes de segurança	123
VIII. Volume 8 — Nuvem e Contêineres	125
50. Modelo de responsabilidade compartilhada	127
51. IAM em nuvem e os erros de configuração mais caros	129
52. Segurança de contêineres e de imagens	131
53. Segurança em Kubernetes	133
54. Infraestrutura como código e segurança de pipeline	135
55. Segredos, cofres e gestão de chaves	137
IX. Volume 9 — Testes de Invasão	139
56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115	141
57. Reconhecimento passivo e OSINT	143
58. Varredura e enumeração	145

59. Análise de vulnerabilidades	147
60. Exploração: conceitos e anatomia de uma falha	149
61. Pós-exploração, persistência e movimentação lateral	151
62. Teste de invasão em aplicações web na prática	153
63. Relatório técnico e comunicação de achados	155
 X. Volume 10 — Fator Humano	 157
64. Engenharia social: os princípios psicológicos da persuasão	159
65. Phishing, spear phishing e fraude do e-mail corporativo	161
66. Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria	163
67. Segurança física e ataques presenciais	165
68. Cultura de segurança e programas de conscientização	167
 XI. Volume 11 — Malware e Inteligência de Ameaças	 169
69. Taxonomia de malware	171
70. Anatomia de um ataque de ransomware	173
71. Análise estática em laboratório	175
72. Análise dinâmica e sandboxing	177
73. MITRE ATT&CK e o mapeamento de TTPs	179
74. Inteligência de ameaças e indicadores de comprometimento	181
 XII. Volume 12 — Blue Team, SOC e Detecção	 183
75. Estrutura e operação de um SOC	185
76. Logging: o que registrar, por quanto tempo e por quê	187
77. SIEM: arquitetura, ingestão e correlação	189
78. Escrita de regras de detecção com Sigma e YARA	191
79. Threat hunting: caçando o que a regra não pegou	193
80. Deception: honeypots, honeytokens e canários	195
81. Métricas e maturidade da detecção	197

XIII Volume 13 — Resposta a Incidentes e Forense Digital	199
82. O ciclo de resposta a incidentes	201
83. Preparação: plano, papéis e playbooks	203
84. Contenção, erradicação e recuperação	205
85. Fundamentos de forense digital e cadeia de custódia	207
86. Forense de disco e sistemas de arquivos	209
87. Forense de memória	211
88. Forense de rede e análise de tráfego	213
 XIV Volume 14 — Continuidade e Resiliência	 215
89. Backup: estratégias e a regra 3-2-1-1-0	217
90. Recuperação de desastres e continuidade de negócio	219
91. Testes de continuidade e exercícios de mesa	221
92. Alta disponibilidade e resiliência de infraestrutura	223
93. Recuperação após um ataque de ransomware	225
 XV. Volume 15 — Governança, Risco e Conformidade	 227
94. Governança de segurança e o papel do CISO	229
95. ISO/IEC 27001 e 27002	231
96. NIST Cybersecurity Framework e CIS Controls	233
97. LGPD na prática: bases legais, incidentes e a ANPD	235
98. Marco Civil, Lei 12.737 e o direito penal digital brasileiro	237
99. Obrigações regulatórias de provedores de internet	239
100. PCI-DSS e requisitos setoriais	241
101. Auditoria, conformidade e gestão de riscos de terceiros	243
 XVI Volume 16 — Fronteira e Carreira	 245
102. Segurança de sistemas de IA e modelos de linguagem	247
103. Criptografia pós-quântica	249
104. Segurança de OT, IoT e sistemas embarcados	251

105	Segurança da cadeia de suprimentos de software	253
106	Privacidade, anonimato e vigilância	255
107	Carreira, certificações e aprendizado contínuo	257
	Referências	259

Apresentação

Este manual cobre segurança da informação do básico ao avançado, em português, com foco em construir entendimento real em vez de decorar siglas. Ele nasce da premissa de que segurança não é uma disciplina isolada: é a consequência de entender profundamente como redes, sistemas operacionais, criptografia e pessoas realmente funcionam — e onde essas engrenagens se desencaixam.

São **107 capítulos** distribuídos em **16 volumes** e **5 fases**, escritos para serem lidos em sequência por quem está começando, e consultados por assunto por quem já atua na área.

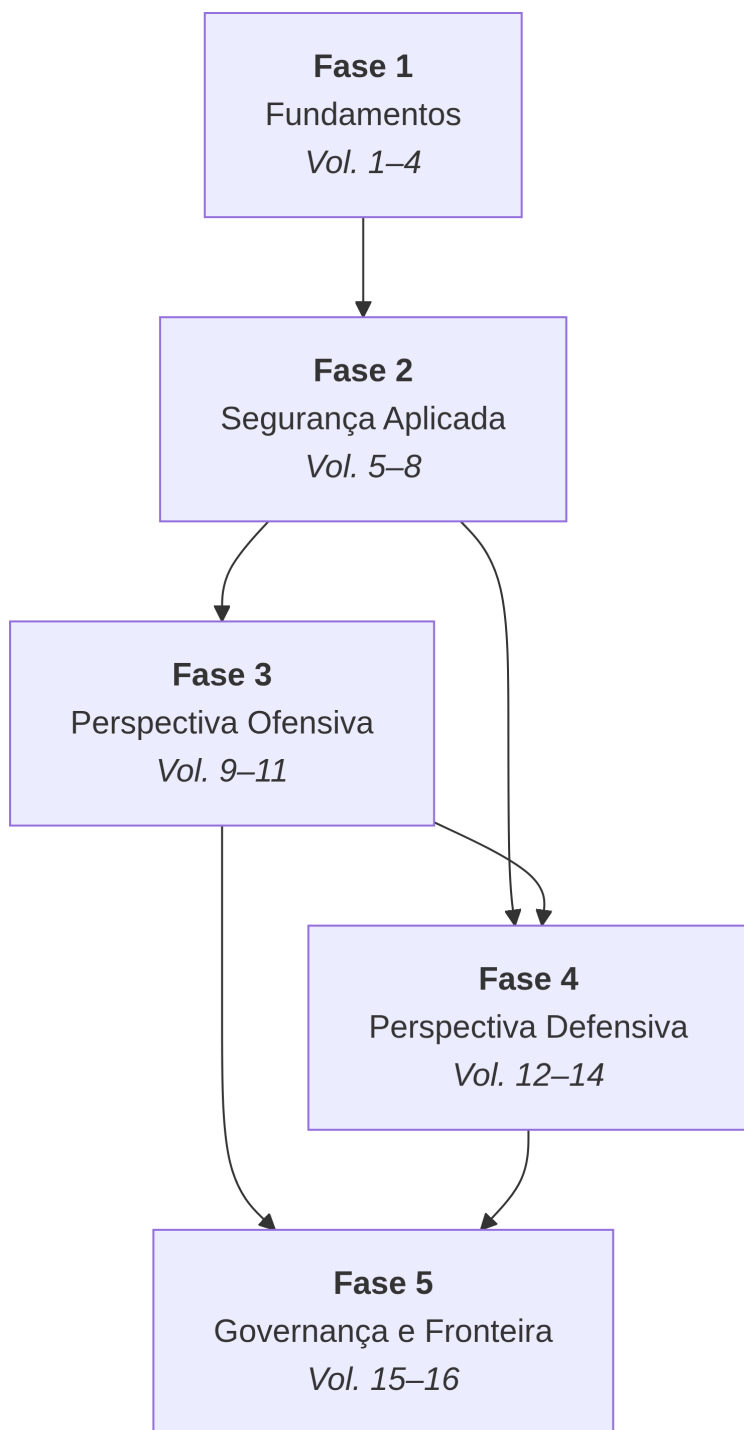
Para quem é este manual

- Quem está entrando na área e quer uma trilha ordenada em vez de tutoriais soltos
- Profissionais de infraestrutura e redes que precisam incorporar segurança ao dia a dia
- Desenvolvedores que querem entender as falhas que produzem sem perceber
- Estudantes preparando-se para certificações (Security+, CEH, CISSP, OSCP) que precisam da base conceitual antes do material de prova

Não é preciso conhecimento prévio de segurança. É preciso, sim, disposição para acompanhar os fundamentos técnicos do Volume 2 antes de correr para as partes mais chamativas.

Como o manual está organizado

```
flowchart TD
    F1["<b>Fase 1</b><br>Fundamentos<br><i>Vol. 1-4</i>"] --> F2["<b>Fase 2</b><br>Segurança Aplicada<br><i>Vol. 5-8</i>"]
    F2 --> F3["<b>Fase 3</b><br>Perspectiva Ofensiva<br><i>Vol. 9-11</i>"]
    F2 --> F4["<b>Fase 4</b><br>Perspectiva Defensiva<br><i>Vol. 12-14</i>"]
    F3 --> F4
    F3 --> F5["<b>Fase 5</b><br>Governança e Fronteira<br><i>Vol. 15-16</i>"]
    F4 --> F5
```



Dependências entre as fases do manual

A **Fase 1** estabelece o vocabulário e a base técnica: o que é risco, como funcionam redes e sistemas, criptografia e controle de acesso. A **Fase 2** aplica isso aos domínios concretos — redes, endpoints, aplicações e nuvem. As fases **3** e **4** apresentam os dois lados da mesma moeda: como se ataca e como se detecta e responde. A **Fase 5** fecha com governança, conformidade brasileira e os temas de fronteira.

Ataque e defesa aparecem nesta ordem por um motivo pedagógico: não se detecta o que não se compreende. Mas as duas fases são complementares, não sequenciais — quem só quer defender pode ler a Fase 4 antes da 3, aceitando algumas referências para frente.

Seções fixas de cada capítulo

Todo capítulo traz duas seções obrigatórias ao final:

i Brasil em Foco — como o tema se conecta à legislação e às instituições brasileiras: LGPD e ANPD, Marco Civil, Lei 12.737, Anatel, CERT.br, Gov.br, Banco Central e Pix.

💡 No Campo — a tradução do conceito para a operação real de infraestrutura: o que muda no dia a dia de quem administra rede, servidores e clientes.

Política editorial

! Escopo, ética e legalidade

Este manual é material educacional com orientação defensiva. Técnicas ofensivas são apresentadas para que se possa **entender, detectar e mitigar** ataques — nunca como receita operacional.

Na prática, isso significa: explicamos mecanismos, usamos ferramentas públicas e consagradas em laboratório isolado, e mostramos as contramedidas correspondentes. Não publicamos exploits armados, payloads prontos para uso, nem código de malware funcional.

Testar sistemas sem autorização formal e por escrito é crime no Brasil (Lei 12.737/2012, art. 154-A do Código Penal). O Volume 9 trata escopo e autorização como pré-requisito, não como formalidade. Monte seu laboratório (Capítulo 14) e pratique apenas nele ou em plataformas que autorizam explicitamente.

Licença

Conteúdo sob licença [CC BY-SA 4.0](#). Código e scripts sob licença MIT. Contribuições, correções e sugestões são bem-vindas via issues no repositório.

Parte I.

**Volume 1 — Fundamentos da
Segurança da Informação**

1. O que é segurança da informação

Numa terça-feira de março, às 6h40, o técnico de plantão de um provedor regional atende o primeiro chamado do dia: um assinante não consegue emitir a segunda via da fatura. Às 7h10 são doze chamados. Às 7h30 fica claro que o problema não é o portal de faturas — é o sistema de gestão inteiro, o ERP que emite boleto, controla contrato e guarda o cadastro de quatro mil assinantes. A tela de login abre. A senha do administrador não é aceita. No servidor, os arquivos do banco de dados continuam todos lá, com uma extensão nova grudada no fim. Na raiz do disco há um arquivo de texto com um endereço de carteira de criptomoeda e um prazo.

Vale olhar primeiro o que **não** falhou naquela manhã. O link de saída estava perfeito, com 6 ms de latência para o PTT. Nenhum alarme do monitoramento disparou, porque o monitoramento vigiava latência, perda de pacote, potência óptica e temperatura de rack — e os quatro estavam normais. O firewall de borda seguia bloqueando exatamente aquilo que alguém havia configurado para bloquear, sem errar um pacote. Toda a infraestrutura funcionou conforme especificada. E a empresa parou por seis dias.

O caminho, reconstruído depois, foi banal. Uma conta de VPN criada dois anos antes para um consultor, com senha reaproveitada de outro serviço que havia vazado, sem segundo fator. De dentro da VPN, uma porta de área de trabalho remota alcançável e uma conta de administrador local repetindo a mesma senha em três servidores. O backup existia — em um compartilhamento de rede montado permanentemente como unidade Z: no próprio servidor do ERP, e por isso foi cifrado junto.

No mesmo mês, essa empresa teve outros dois incidentes que ninguém chamou de incidente. Um notebook do comercial foi furtado de dentro de um carro, com uma planilha de 1.200 assinantes — nome, CPF, endereço, telefone — em disco sem cifragem. E um técnico desligado em janeiro seguiu com acesso administrativo à OLT por 40 dias, porque o desligamento passou pelo RH e pela folha, mas não por ninguém que soubesse quais credenciais aquela pessoa carregava.

Os três episódios são incidentes de segurança da informação. Nenhum dos três se resolve comprando um equipamento. É desse desconforto que a disciplina nasce.

1.1. Uma definição de trabalho

A norma ISO/IEC 27000 define segurança da informação como a **preservação da confidencialidade, da integridade e da disponibilidade da informação** (International Organization for Standardization, 2018). É uma frase curta e bem mais densa do que parece.

Preservação implica continuidade: não é estado que se alcança e se declara, é algo que se mantém contra uma tendência natural de degradação. *Informação* — não servidor, não rede, não software. E as três propriedades, que o próximo capítulo abre em detalhe:

- **Confidencialidade** — a informação só é acessível a quem tem direito a ela.
- **Integridade** — a informação está correta e completa, e alterações não autorizadas são impedidas ou, no mínimo, detectáveis.
- **Disponibilidade** — quem tem direito à informação a alcança quando precisa.

1. O que é segurança da informação

Os três pilares são necessários, mas não bastam: uma transação bancária exige também que a origem seja comprovadamente quem afirma ser (autenticidade) e que depois não possa negar tê-la feito (não repúdio) — assunto do capítulo seguinte ao próximo.

A definição operacional que este manual carrega é esta:

Segurança da informação é o conjunto de decisões — técnicas, organizacionais e humanas — que mantém a informação disponível para quem tem direito a ela, íntegra para quem depende dela e inalcançável para quem não deveria chegar até ela, dentro de um custo que a organização consegue sustentar de forma contínua.

A última cláusula é a que separa segurança de teatro de segurança: um controle que a empresa não consegue pagar, operar e manter por três anos não é controle, é linha de relatório.

Vale notar desde já que os três pilares **entram em conflito entre si**. Cifrar o backup protege a confidencialidade e cria um risco novo de disponibilidade: chave perdida significa backup inútil. Exigir troca de senha a cada 30 dias parece reforçar o controle de acesso e, na prática, produz **Verão2026!** escrito num post-it colado no monitor da recepção. Segurança da informação é, em boa medida, escolher esses tradeoffs conscientemente em vez de tropeçar neles.

1.2. Dado, informação e ativo: o que exatamente se protege

10.20.0.42 é um dado. “Endereço de gerência da OLT do distrito de Santa Rita, acessível apenas pela VLAN 900” é informação: o dado mais o contexto que o torna útil — e, no mesmo movimento, útil para um atacante.

Ativo é qualquer coisa que tenha valor para a organização, e separá-los em dois níveis é prático:

- **Ativos primários** — a informação em si e os processos de negócio que dependem dela. O cadastro de assinantes. A base de contratos. A capacidade de faturar no dia 5.
- **Ativos de suporte** — o que sustenta os primários: hardware, software, rede, instalações, e as pessoas. O servidor do ERP, a fibra do backbone, a torre de rádio, o técnico que sabe reconfigurar a OLT.

A inversão que a disciplina propõe é esta: o objeto de proteção é o ativo primário, mas os controles quase sempre se aplicam aos de suporte. Ninguém cifra “o cadastro de assinantes” em abstrato — cifra-se o disco, restringe-se a conta, segmenta-se a VLAN.

E a informação não fica parada: percorre um ciclo, e cada etapa tem controles próprios (Figura 1.1).

O descarte é a etapa esquecida com mais frequência, e a que produz vazamentos mais silenciosos: o disco do servidor trocado por defeito que vai para o ferro-velho com o banco de dados legível; o roteador de borda vendido em marketplace com a configuração completa da rede, incluindo chaves de BGP. Nenhum desses casos tem atacante, exploração ou malware. Todos são falhas de confidencialidade.

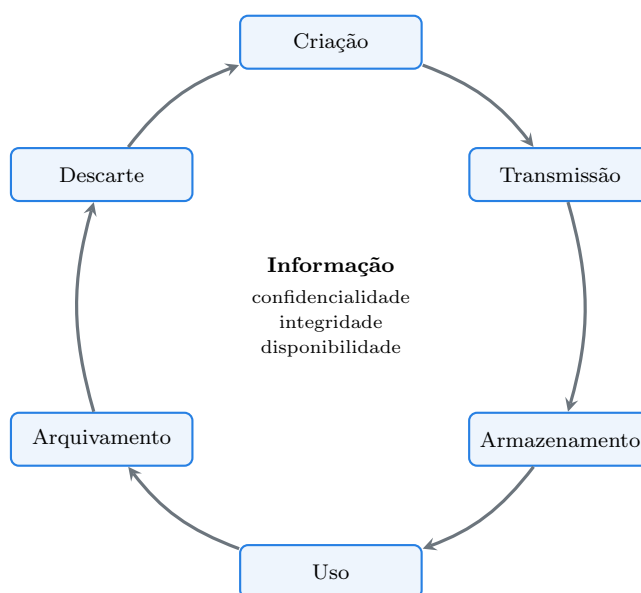


Figura 1.1.: O ciclo de vida da informação. Um controle que só cobre uma etapa deixa as outras cinco expostas.

1.3. Segurança não é um estado, é um processo

A frase é de Bruce Schneier e virou clichê justamente porque resolve uma confusão persistente (Schneier, 2000). Segurança absoluta é alcançável: desliga-se o equipamento, retira-se o disco, lacra-se num cofre. O sistema fica perfeitamente seguro e perfeitamente inútil. Todo sistema real opera num ponto intermediário, e o nome desse ponto é **risco residual**.

O que a disciplina persegue não é risco zero, é risco residual *conhecido e aceito conscientemente* — decidido por quem tem autoridade, documentado e revisitado. A diferença entre uma empresa madura e uma imprudente raramente está no número de controles: está em saber, ou não saber, o que ficou descoberto.

Existe uma razão econômica para isso, esboçada em Figura 1.2.

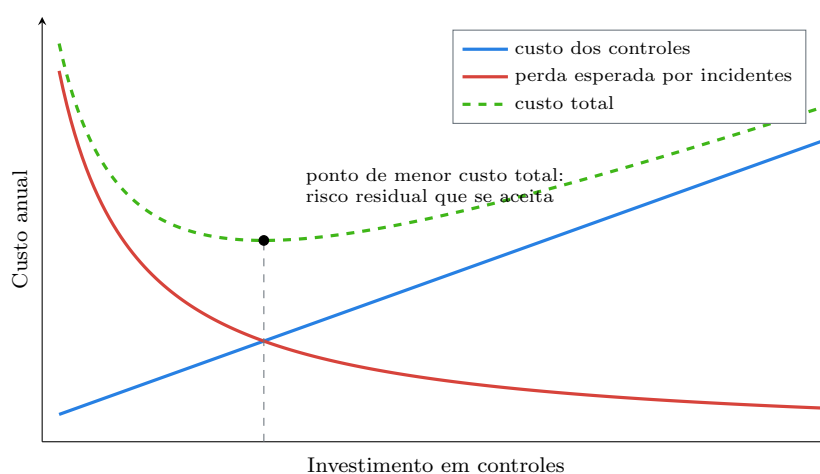


Figura 1.2.: A lógica econômica do controle. Passado certo ponto, cada real gasto em segurança compra menos redução de perda esperada do que custa.

1. O que é segurança da informação

O gráfico é uma idealização didática: na vida real não se conhecem os valores das curvas com precisão, e é por isso que existe gestão de risco como método — tema do sexto capítulo deste volume. O que importa é a *forma*: há um ponto além do qual gastar mais destrói valor, e um ponto abaixo do qual economizar destrói a empresa.

Há uma segunda razão para tratar segurança como processo: **as configurações envelhecem**. Um servidor perfeitamente endurecido em 2023 acumula, até 2026, bibliotecas com falhas conhecidas, cifras que deixaram de ser aceitáveis e regras de firewall abertas “temporariamente” para um teste que ninguém fechou. Toda base de regras com cinco anos contém alguma liberação cuja justificativa ninguém sabe mais explicar, e que ninguém remove por medo de derrubar algo.

1.4. Pessoas, processos e tecnologia

O incidente da abertura é um exemplo didático de por que a tecnologia isolada não fecha a conta. Vale reler o caso separando as camadas:

Tabela 1.1.: As três camadas do incidente de abertura.

Camada	O que falhou
Tecnologia	VPN sem segundo fator, rede interna plana, senha de administrador local repetida, backup em unidade montada
Processo	desligamento sem revogação de credencial, nenhuma revisão periódica de contas, backup nunca testado por restauração
Pessoas	senha reaproveitada de outro serviço, conta de terceiro esquecida ativa por dois anos

Nenhuma das três falhas de processo custa dinheiro para corrigir; todas custam disciplina, que é mais escassa. E o investimento típico vai no sentido inverso — 90% do orçamento em tecnologia —, o que explica por que empresas bem equipadas continuam sendo comprometidas por caminhos elementares.

1.5. O adversário não é só o hacker

A palavra “ameaça” evoca uma pessoa mal-intencionada, e essa associação estreita indevidamente o campo. Convencionalmente, separam-se três origens:

Deliberadas. Ação intencional de um agente: fraude, extorsão por ransomware, sabotagem, espionagem, furto de equipamento.

Acidentais. Erro humano sem intenção: o comando DROP no banco de produção em vez do de teste; a rota redistribuída por engano que anuncia prefixo de terceiro; o e-mail com anexo de dados pessoais enviado para a lista errada. Em volume de incidentes, esta categoria rivaliza com a primeira — e em algumas organizações a supera.

Ambientais e naturais. Descarga atmosférica na torre de rádio que leva switch, conversor e fonte no mesmo estouro. Falta de energia de nove horas num site remoto cujo banco de baterias tem autonomia de duas. Roçadeira de trator que rompe o ramal de fibra do distrito na época da

colheita. Furto de bateria de nobreak em site sem cerca — que, para quem opera rede rural, é ameaça deliberada e ambiental ao mesmo tempo.

Para quem administra infraestrutura, essa terceira categoria é com frequência a maior fonte de horas de indisponibilidade do ano — e disponibilidade é um dos três pilares. Não é curiosidade taxonômica: o mesmo arcabouço (inventariar ativos, estimar risco, implantar controle, exercitar resposta) serve para o raio e para o ransomware. Plano de resposta que só sabe lidar com atacante é metade de um plano.

1.6. Quem ataca, e por que o pequeno também é alvo

Entre os agentes deliberados, os perfis diferem tanto em capacidade quanto em motivação, e a diferença muda a defesa apropriada:

- **Oportunista automatizado.** Não escolheu você. Varre faixas inteiras de endereços procurando serviço exposto com credencial padrão ou falha conhecida. É a esmagadora maioria do que se vê nos logs.
- **Crime organizado.** Opera como negócio, com divisão de trabalho: quem obtém o acesso inicial vende para quem executa a extorsão, que aluga o programa de cifragem de um terceiro. É a economia que tornou ransomware viável contra empresas de qualquer porte.
- **Pessoa interna.** Do funcionário insatisfeito com acesso privilegiado ao terceirizado negligente que reutiliza senha. Não precisa vencer perímetro nenhum: já está dentro.
- **Ativismo.** Motivação ideológica, alvo escolhido pelo que representa e busca de visibilidade: pichação de site, vazamento seletivo, indisponibilidade em data simbólica.
- **Estado-nação.** Recursos altos, paciência longa, alvo deliberadamente escolhido. Raro como adversário direto de uma empresa média — mas provedores de telecomunicações e cadeias de suprimento são alvos de interesse justamente por serem caminho para outros.

Um servidor SSH recém-exposto coleta tentativas de acesso em minutos, sempre com esta cara:

```
Mar 12 03:11:44 borda sshd[2291]: Failed password for invalid user admin from
↪ 203.0.113.47 port 51344 ssh2
Mar 12 03:11:46 borda sshd[2293]: Failed password for invalid user ubnt from
↪ 203.0.113.47 port 51402 ssh2
Mar 12 03:11:49 borda sshd[2295]: Invalid user support from 198.51.100.12 port
↪ 44120
Mar 12 03:11:52 borda sshd[2297]: Failed password for root from 198.51.100.12
↪ port 44188 ssh2
Mar 12 03:12:03 borda sshd[2301]: Failed password for invalid user pi from
↪ 203.0.113.190 port 33012 ssh2
```

Os nomes de usuário entregam o jogo: **admin**, **ubnt**, **support** e **pi** são credenciais de fábrica de equipamentos de rede e placas embarcadas. Ninguém decidiu atacar aquele endereço — um programa varre a internet inteira, e o endereço apareceu na lista. O custo marginal de tentar em um alvo a mais é zero, e é por isso que “sou pequeno, ninguém vai me atacar” é premissa falsa por construção.

Há um segundo motivo, mais específico. Uma empresa pequena que administra rede guarda dados pessoais em volume (CPF, endereço, meio de pagamento) e opera equipamentos de cliente que, tomados em massa, valem como capacidade de ataque: milhares de roteadores domésticos com credencial padrão são ativo de mercado para quem monta rede de ataque distribuído. Nessa configuração, a infraestrutura não é apenas alvo — é vetor contra os próprios assinantes.

1.7. Os princípios que sustentam qualquer defesa

Em 1975, Saltzer e Schroeder publicaram oito princípios de projeto para proteção da informação (Saltzer; Schroeder, 1975). Cinco décadas depois, com toda a tecnologia trocada, seguem sendo o melhor filtro para avaliar uma decisão de segurança:

1. **Economia de mecanismo.** O desenho mais simples que resolve. Complexidade é onde erro se esconde.
2. **Padrões à prova de falha.** Negar por padrão; permitir por exceção explícita. Se o mecanismo falhar, deve falhar fechado.
3. **Mediação completa.** Toda requisição verificada, sempre. Atalhos de desempenho que reaproveitam decisões antigas de autorização são a origem de uma classe inteira de falhas.
4. **Desenho aberto.** A segurança não deve depender do segredo do desenho, apenas do segredo da chave. Criptografia proprietária “secreta” é sinal de alerta, não de força.
5. **Separação de privilégios.** Exigir mais de uma condição independente para a operação crítica — a lógica das duas chaves do cofre, e a razão de ser da autenticação em dois fatores.
6. **Menor privilégio.** Cada sujeito com o mínimo de permissão necessário, pelo menor tempo necessário. É o princípio mais violado da lista: quase toda rede tem contas de serviço com privilégio administrativo porque “assim funciona”.
7. **Mecanismo menos comum.** Evitar compartilhar mecanismo e estado entre usuários diferentes; o que é compartilhado se torna caminho entre eles.
8. **Aceitação psicológica.** O controle precisa ser utilizável. Controle que atrapalha o trabalho é controle burlado — e a criatividade do usuário para burlar é ilimitada.

Desses princípios decorre a estratégia que organiza tudo o que vem nos volumes seguintes: **defesa em profundidade**. Nenhuma camada é considerada confiável o suficiente para ser a única, e o comprometimento de uma não deve implicar o comprometimento das demais (Figura 1.3).

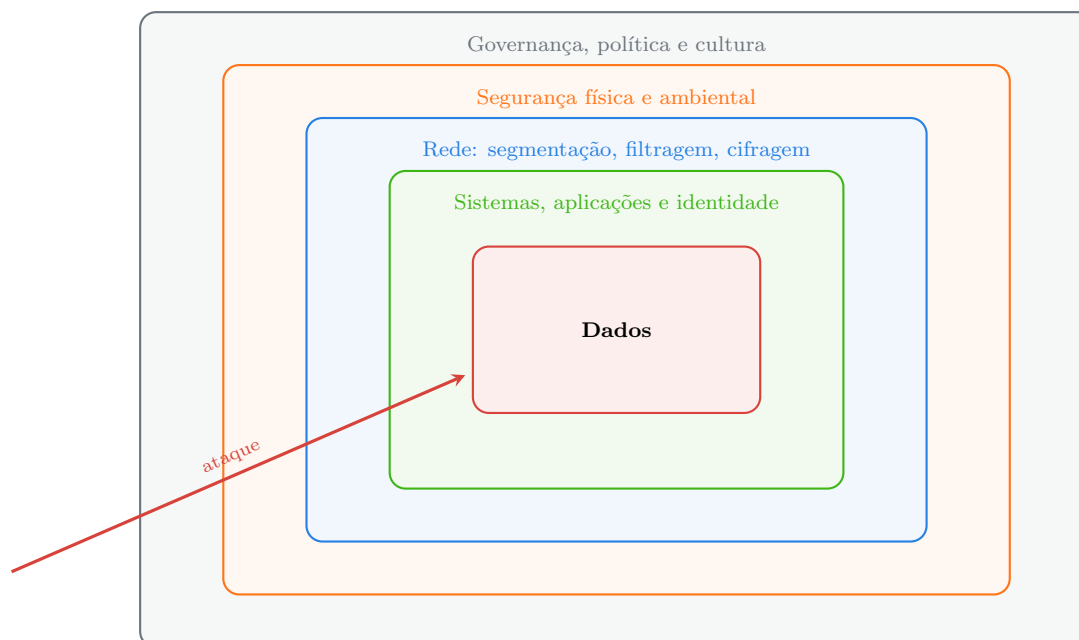


Figura 1.3.: Defesa em profundidade. Cada camada compra tempo e gera registro; nenhuma é suficiente sozinha.

Duas ressalvas importam desde já. Camadas precisam ser **independentes**: cinco que aceitam a mesma senha de administrador são, na prática, uma. E camadas servem para *detectar*, não

só para bloquear — o valor de uma camada intermediária costuma estar menos em barrar o atacante do que em produzir o registro que revela sua passagem enquanto há tempo de reagir. Assumir que o comprometimento vai acontecer e projetar para detectá-lo rápido atravessa toda a parte defensiva deste manual.

1.8. O vocabulário mínimo

Segurança da informação tem vocabulário próprio, em que palavras do uso cotidiano ganham sentido técnico estrito. Confundi-las produz conversas em que ninguém está errado e ninguém se entende. A Tabela 1.2 fixa o mínimo para seguir adiante; o quarto capítulo deste volume aprofunda cada termo.

Tabela 1.2.: Vocabulário mínimo de segurança da informação.

Termo	Sentido técnico	No caso de abertura
Ativo	Aquilo que tem valor e que se quer proteger	O cadastro dos quatro mil assinantes
Vulnerabilidade	Fraqueza que pode ser explorada	VPN sem segundo fator; senha repetida entre servidores
Ameaça	Agente ou evento com potencial de causar dano	Grupo de extorsão que compra acesso inicial
Risco	Combinação de probabilidade e impacto de a ameaça explorar a vulnerabilidade	Alta chance de parada de faturamento por vários dias
Controle	Medida que reduz risco, por prevenção, detecção ou correção	Segundo fator na VPN; backup fora do alcance do servidor
Evento	Qualquer ocorrência observável no ambiente	Uma autenticação falha às 3h11
Incidente	Evento, ou série de eventos, que compromete um dos pilares	A cifragem do banco de dados do ERP
Superfície de ataque	Conjunto de pontos alcançáveis por um adversário	VPN, área de trabalho remota, portal do assinante
Risco residual	O que permanece depois dos controles aplicados	O que se decide conviver, sabendo que existe

Duas dessas distinções têm consequência operacional direta. Uma rede grande gera milhões de *eventos* por dia, e a função de um centro de operações é separar os poucos que são *incidentes*. E como não se elimina a *ameaça* — ninguém acaba com o crime organizado a partir do datacenter —, o trabalho recai sobre reduzir vulnerabilidade e impacto.

1.9. Como se sabe se está funcionando

“Nunca fomos invadidos” não é evidência de segurança; costuma ser evidência de ausência de detecção — comprometimentos que duram meses sem serem percebidos são a regra, e a descoberta vem com frequência de fora: um cliente, um pesquisador, ou o próprio atacante ao pedir resgate.

1. O que é segurança da informação

Medir é difícil justamente porque o resultado desejado é a não ocorrência de algo, mas alguns indicadores sobrevivem ao escrutínio:

- **Tempo até detectar e tempo até conter.** Se a resposta é “não sabemos”, esse é o primeiro problema a resolver.
- **Cobertura de controle sobre inventário.** Percentual de ativos inventariados, de contas com segundo fator, de servidores corrigidos no prazo, de backups cuja restauração foi testada no trimestre. Todas dependem de existir inventário.
- **Superfície exposta.** Quantidade de serviços administrativos alcançáveis da internet. A meta é zero, e o número é fácil de medir.
- **Resultado de exercícios.** Restauração real a partir do backup, simulação controlada de phishing, exercício de mesa. Exercício produz dado; opinião produz sensação.

Métrica que só sobe e nunca gera decisão é métrica de vaidade: contar ataques bloqueados pelo firewall mede o ruído de fundo da internet, não a qualidade da defesa. O Volume 12 retoma o assunto com o rigor devido.

1.10. Brasil em Foco

No Brasil, segurança da informação deixou de ser boa prática e passou a ser obrigação jurídica com nome, prazo e sanção.

A **Lei Geral de Proteção de Dados** (Lei 13.709/2018) é o eixo (Brasil, 2018). Seu art. 46 obriga os agentes de tratamento a adotar medidas de segurança técnicas e administrativas aptas a proteger dados pessoais — redação deliberadamente aberta, que remete ao estado da técnica e à natureza da informação, e não a uma lista fechada de produtos. O art. 48 estabelece o dever de comunicar à Autoridade Nacional de Proteção de Dados e aos titulares afetados a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante. A Resolução CD/ANPD nº 15/2024 regulamentou essa comunicação, fixando prazo de três dias úteis a contar do conhecimento do incidente e definindo o conteúdo mínimo do relato (Autoridade Nacional de Proteção de Dados, 2024). Na prática, a empresa precisa ser capaz de *saber* que foi comprometida, *avaliar* o alcance e *redigir* a comunicação em três dias — impossível sem registro adequado e plano prévio. No caso da abertura, a planilha do notebook furtado é tratamento de dados pessoais, e o furto é potencialmente um incidente comunicável.

O **Marco Civil da Internet** (Lei 12.965/2014) trata da guarda de registros (Brasil, 2014). O art. 13 obriga o provedor de conexão a manter registros de conexão por um ano; o art. 15 obriga o provedor de aplicações constituído como pessoa jurídica e com fins econômicos a guardar registros de acesso por seis meses. Os arts. 10 e 11 impõem sigilo e condicionam a disponibilização a ordem judicial. A leitura é dupla: o registro é obrigação e é ativo sensível — quem guarda log de conexão de milhares de pessoas custodia um alvo de valor.

A **Lei 12.737/2012** inseriu no Código Penal o art. 154-A, que tipifica invadir dispositivo informático alheio para obter, adulterar ou destruir dados, ou instalar vulnerabilidade para obter vantagem ilícita (Brasil, 2012). As penas foram agravadas pela Lei 14.155/2021. Essa é a fronteira jurídica que sustenta a política editorial deste manual: testar sistema de terceiro sem autorização formal e por escrito é crime, ainda que a intenção seja “só verificar”. O sétimo capítulo deste volume trata exclusivamente dessa fronteira.

Para quem opera telecomunicações há camada regulatória adicional: a **Anatel** editou a Resolução nº 740/2020, com requisitos de segurança cibernética para produtos de telecomunicações, o que alcança diretamente as ONUs e roteadores entregues ao assinante (Agência Nacional

de Telecomunicações, 2020). O Volume 15 dedica um capítulo às obrigações regulatórias de provedores.

No lado institucional, o **CERT.br**, mantido pelo NIC.br, é o ponto nacional de tratamento de incidentes em redes conectadas à internet no Brasil: recebe notificações, publica estatísticas e mantém material de boas práticas usado por operadores de rede. Manter contato de abuso atualizado no WHOIS do seu bloco e responder de fato a essas notificações é um dos controles mais baratos e menos praticados do país.

Por fim, o **Banco Central** trata fraude como matéria de segurança regulada: instituições financeiras e de pagamento estão sujeitas a política obrigatória de segurança cibernética (Resolução CMN nº 4.893/2021), e o Pix conta com o Mecanismo Especial de Devolução para casos de fraude — o que faz da engenharia social contra o titular, e não do ataque à instituição, o vetor dominante no país. O Volume 10 volta ao tema.

1.11. No Campo

Traduzindo tudo para a primeira semana de quem assume a responsabilidade por uma infraestrutura, na ordem em que compensa fazer:

1. Inventário, antes de qualquer controle. Não se protege o que não se conhece, e a maior parte das surpresas está em ativo esquecido: o servidor de teste de 2019 ainda ligado com endereço público, a câmera com firmware de fábrica. Vale a varredura do próprio bloco — sua rede, sua autorização:

```
# Descoberta de hosts e serviços no PRÓPRIO bloco de endereços
nmap -sS -Pn --top-ports 200 --open -oA inventario-borda 198.51.100.0/24

# O que este servidor realmente escuta, e qual processo responde
ss -tulnp | sort -k5

# Contas locais com shell de login válido
awk -F: '$7 !~ /(nologin|false)$/ {print $1, $3, $7}' /etc/passwd
```

2. Reduzir a superfície de gerência. Painel de administração acessível da internet é o achado mais comum e mais caro. Winbox, interface web de OLT, SNMP com comunidade `public`, Telnet, área de trabalho remota — nada disso deve estar alcançável do mundo. O padrão é VLAN de gerência separada do tráfego de assinante, alcançável apenas por VPN com segundo fator, com filtro por origem no equipamento além do filtro na borda.

3. Senhas individuais e nomeadas. A senha compartilhada entre a equipe técnica destrói o menor privilégio e a responsabilização de uma vez: quando todos entram como `admin`, o log de auditoria não responde à única pergunta que importa depois de um incidente. Cofre de senhas da equipe, contas nomeadas e revogação como parte formal do desligamento — inclusive chaves SSH, VPN e acesso ao WhatsApp do suporte.

4. Backup que sobrevive ao próprio servidor. O critério é implacável: o backup precisa estar fora do alcance de quem comprometeu o servidor — compartilhamento montado permanentemente não atende, cópia que a máquina de origem pode apagar não atende. E backup nunca restaurado é hipótese, não backup; a restauração de teste trimestral é o que transforma um em outro.

1. O que é segurança da informação

5. Relógio e registro. Sem NTP consistente em todos os equipamentos, os logs não podem ser correlacionados e perdem valor tanto na investigação técnica quanto no atendimento a ordem judicial. É configuração de dez minutos com efeito permanente:

```
timedatectl set-ntp true
timedatectl status | grep -E 'synchronized|NTP service'

# Autenticações falhas por origem, últimas 24 h
journalctl -u ssh --since "24 hours ago" \
  | grep -oE 'from [0-9.]+' | sort | uniq -c | sort -rn | head
```

6. Escrever o plano antes de precisar dele. Uma folha por cenário, resposta a três perguntas: quem decide, a quem se avisa (interno, cliente, ANPD, delegacia), e qual é a primeira ação técnica. Faça para ransomware no sistema de gestão, para vazamento de base de assinantes e para rompimento de fibra do enlace principal. Às 3h da manhã, com o telefone tocando, ninguém improvisa bem.

7. Fechar o ciclo no descarte. Disco que sai da empresa é apagado de forma verificável ou destruído fisicamente. Equipamento devolvido por assinante ou retirado de operação volta a padrão de fábrica antes de ir para o estoque, para venda ou para doação.

Nenhum dos sete itens exige orçamento significativo; todos exigem que alguém seja nomeado responsável — e essa nomeação, mais do que qualquer aquisição, é o que dá início a um programa de segurança.

1.12. Resumo

- Segurança da informação é a **preservação contínua** de confidencialidade, integridade e disponibilidade: processo que se mantém, não estado que se compra. As três propriedades conflitam entre si, e escolher os tradeoffs conscientemente é parte do trabalho.
- O que se protege é a **informação**; servidores, links e equipamentos são ativos de suporte, e é neles que os controles se aplicam — em todo o ciclo de vida, inclusive no descarte, a etapa mais esquecida.
- Ameaça não é sinônimo de atacante: falhas **acidentais** e eventos **ambientais** produzem incidentes de disponibilidade em volume, e cabem no mesmo arcabouço de gestão de risco.
- A maior parte do que se vê nos logs é **varredura automatizada e indiscriminada** — o que invalida a premissa de que porte pequeno confere proteção. Além de alvo, uma infraestrutura mal protegida se torna vetor contra os próprios clientes.
- Os oito princípios de Saltzer e Schroeder, com meio século de idade, seguem sendo o melhor filtro para avaliar decisões; deles decorre a **defesa em profundidade**, com camadas independentes que bloqueiam e também produzem registro.
- No Brasil, o dever de segurança é jurídico: LGPD (arts. 46 e 48) com prazo de três dias úteis para comunicar incidente relevante, Marco Civil para guarda de registros, Lei 12.737/2012 tipificando o acesso não autorizado, mais camada setorial de Anatel e Banco Central.

2. Os pilares: confidencialidade, integridade e disponibilidade

(em elaboracao)

3. Autenticidade, não repúdio e responsabilização

(em elaboracao)

4. Ativos, ameaças, vulnerabilidades e risco

(em elaboracao)

5. Modelagem de ameaças: STRIDE, árvores de ataque e abuse cases

(em elaboracao)

6. Gestão de risco: análise qualitativa e quantitativa

(em elaboracao)

7. Ética, legalidade e a fronteira do escopo autorizado

(em elaboracao)

Parte II.

**Volume 2 — Redes e Sistemas: a Base
Técnica**

8. A pilha TCP/IP sob a ótica do atacante e do defensor

(em elaboracao)

9. Endereçamento, roteamento e NAT

(em elaboracao)

10. Protocolos de aplicação e seus riscos: HTTP, DNS, SMTP e SNMP

(em elaboracao)

11. Fundamentos de sistemas operacionais: processos, permissões e memória

(em elaboracao)

12. Linux essencial para segurança

(em elaboracao)

13. Windows e Active Directory essencial

(em elaboracao)

14. Virtualização e montagem do laboratório de estudos

(em elaboracao)

Parte III.

Volume 3 — Criptografia Aplicada

15. História e princípios da criptografia

(em elaboracao)

16. Criptografia simétrica: AES, modos de operação e AEAD

(em elaboracao)

17. Funções hash, HMAC e integridade

(em elaboracao)

18. Criptografia assimétrica: RSA, Diffie-Hellman e curvas elípticas

(em elaboracao)

19. PKI, certificados digitais e cadeias de confiança

(em elaboracao)

20. TLS na prática: handshake, versões e configuração segura

(em elaboracao)

21. Erros clássicos: criptografia mal empregada

(em elaboracao)

Parte IV.

**Volume 4 — Identidade, Autenticação e
Controle de Acesso**

22. Modelos de controle de acesso: DAC, MAC, RBAC e ABAC

(em elaboracao)

23. Senhas: armazenamento, políticas e ataques

(em elaboracao)

24. Autenticação multifator e fatores de autenticação

(em elaboracao)

25. Federação de identidade: SAML, OAuth 2.0 e OpenID Connect

(em elaboracao)

26. Gestão de identidades e de acessos privilegiados (IAM e PAM)

(em elaboracao)

27. Arquitetura Zero Trust

(em elaboracao)

Parte V.

Volume 5 — Segurança de Redes

28. Arquitetura segura e segmentação de redes

(em elaboracao)

29. Firewalls: tipos, políticas e boas práticas

(em elaboracao)

30. VPNs: IPsec, WireGuard e acesso remoto seguro

(em elaboracao)

31. IDS, IPS e detecção em rede

(em elaboracao)

32. Segurança de DNS: ataques, DNSSEC e DoH

(em elaboracao)

33. Segurança do roteamento e BGP: sequestros, vazamentos e RPKI

(em elaboracao)

34. Segurança em redes sem fio e enlaces de rádio

(em elaboracao)

35. Ataques de negação de serviço e estratégias de mitigação

(em elaboracao)

Parte VI.

**Volume 6 — Endpoints e Sistemas
Operacionais**

36. Hardening de servidores Linux

(em elaboracao)

37. Hardening de Windows e Active Directory

(em elaboracao)

38. Antivírus, EDR e XDR

(em elaboracao)

39. Gestão de vulnerabilidades e ciclo de patches

(em elaboracao)

40. Segurança de dispositivos móveis e BYOD

(em elaboracao)

41. Criptografia de disco e proteção de dados em repouso

(em elaboracao)

Parte VII.

Volume 7 — Segurança de Aplicações

42. Ciclo de desenvolvimento seguro e DevSecOps

(em elaboracao)

43. OWASP Top 10: panorama e como usar

(em elaboracao)

44. Injeção: SQL, NoSQL e comandos de sistema

(em elaboracao)

45. Cross-site scripting e ataques no lado do cliente

(em elaboracao)

46. Falhas de autenticação e gestão de sessão

(em elaboracao)

47. Falhas de controle de acesso: IDOR, SSRF e escalonamento

(em elaboracao)

48. Segurança de APIs REST e GraphQL

(em elaboracao)

49. SAST, DAST, SCA e automação de testes de segurança

(em elaboracao)

Parte VIII.

Volume 8 — Nuvem e Contêineres

50. Modelo de responsabilidade compartilhada

(em elaboracao)

51. IAM em nuvem e os erros de configuração mais caros

(em elaboracao)

52. Segurança de contêineres e de imagens

(em elaboracao)

53. Segurança em Kubernetes

(em elaboracao)

54. Infraestrutura como código e segurança de pipeline

(em elaboracao)

55. Segredos, cofres e gestão de chaves

(em elaboracao)

Parte IX.

Volume 9 — Testes de Invasão

56. Metodologias e definição de escopo: PTES, OSSTMM e NIST SP 800-115

(em elaboracao)

57. Reconhecimento passivo e OSINT

(em elaboracao)

58. Varredura e enumeração

(em elaboracao)

59. Análise de vulnerabilidades

(em elaboracao)

60. Exploração: conceitos e anatomia de uma falha

(em elaboracao)

61. Pós-exploração, persistência e movimentação lateral

(em elaboracao)

62. Teste de invasão em aplicações web na prática

(em elaboracao)

63. Relatório técnico e comunicação de achados

(em elaboracao)

Parte X.

Volume 10 — Fator Humano

64. Engenharia social: os princípios psicológicos da persuasão

(em elaboracao)

65. Phishing, spear phishing e fraude do e-mail corporativo

(em elaboracao)

66. Fraudes digitais no Brasil: Pix, clonagem e golpes por mensageria

(em elaboracao)

67. Segurança física e ataques presenciais

(em elaboracao)

68. Cultura de segurança e programas de conscientização

(em elaboracao)

Parte XI.

**Volume 11 — Malware e Inteligência de
Ameaças**

69. Taxonomia de malware

(em elaboracao)

70. Anatomia de um ataque de ransomware

(em elaboracao)

71. Análise estática em laboratório

(em elaboracao)

72. Análise dinâmica e sandboxing

(em elaboracao)

73. MITRE ATT&CK e o mapeamento de TTPs

(em elaboracao)

74. Inteligência de ameaças e indicadores de comprometimento

(em elaboracao)

Parte XII.

**Volume 12 — Blue Team, SOC e
Detecção**

75. Estrutura e operação de um SOC

(em elaboracao)

76. Logging: o que registrar, por quanto tempo e por quê

(em elaboracao)

77. SIEM: arquitetura, ingestão e correlação

(em elaboracao)

78. Escrita de regras de detecção com Sigma e YARA

(em elaboracao)

79. Threat hunting: caçando o que a regra não pegou

(em elaboracao)

80. Deception: honeypots, honeytokens e canários

(em elaboracao)

81. Métricas e maturidade da detecção

(em elaboracao)

Parte XIII.

**Volume 13 — Resposta a Incidentes e
Forense Digital**

82. O ciclo de resposta a incidentes

(em elaboracao)

83. Preparação: plano, papéis e playbooks

(em elaboracao)

84. Contenção, erradicação e recuperação

(em elaboracao)

85. Fundamentos de forense digital e cadeia de custódia

(em elaboracao)

86. Forense de disco e sistemas de arquivos

(em elaboracao)

87. Forense de memória

(em elaboracao)

88. Forense de rede e análise de tráfego

(em elaboracao)

Parte XIV.

Volume 14 — Continuidade e Resiliência

89. Backup: estratégias e a regra 3-2-1-1-0

(em elaboracao)

90. Recuperação de desastres e continuidade de negócio

(em elaboracao)

91. Testes de continuidade e exercícios de mesa

(em elaboracao)

92. Alta disponibilidade e resiliência de infraestrutura

(em elaboracao)

93. Recuperação após um ataque de ransomware

(em elaboracao)

Parte XV.

**Volume 15 — Governança, Risco e
Conformidade**

94. Governança de segurança e o papel do CISO

(em elaboracao)

95. ISO/IEC 27001 e 27002

(em elaboracao)

96. NIST Cybersecurity Framework e CIS Controls

(em elaboracao)

97. LGPD na prática: bases legais, incidentes e a ANPD

(em elaboracao)

98. Marco Civil, Lei 12.737 e o direito penal digital brasileiro

(em elaboracao)

99. Obrigações regulatórias de provedores de internet

(em elaboracao)

100. PCI-DSS e requisitos setoriais

(em elaboracao)

101. Auditoria, conformidade e gestão de riscos de terceiros

(em elaboracao)

Parte XVI.

Volume 16 — Fronteira e Carreira

102. Segurança de sistemas de IA e modelos de linguagem

(em elaboracao)

103. Criptografia pós-quântica

(em elaboracao)

104. Segurança de OT, IoT e sistemas embarcados

(em elaboracao)

105. Segurança da cadeia de suprimentos de software

(em elaboracao)

106. Privacidade, anonimato e vigilância

(em elaboracao)

107. Carreira, certificações e aprendizado contínuo

(em elaboracao)

Referências

AGÊNCIA NACIONAL DE TELECOMUNICAÇÕES. **Resolução n. 740, de 21 de dezembro de 2020. Regulamento de Segurança Cibernética Aplicada aos Produtos de Telecomunicações.**, 2020.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. **Resolução CD/ANPD n. 15, de 24 de abril de 2024. Aprova o Regulamento de Comunicação de Incidente de Segurança.**, 2024.

BRASIL. **Lei n. 12.737, de 30 de novembro de 2012. Tipificação criminal de delitos informáticos.**, 2012.

BRASIL. **Lei n. 12.965, de 23 de abril de 2014. Marco Civil da Internet.**, 2014.

BRASIL. **Lei n. 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais.**, 2018.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27000: information technology — security techniques — information security management systems — overview and vocabulary.** GenebraISO, 2018.

SALTZER, Jerome H.; SCHROEDER, Michael D. The Protection of Information in Computer Systems. **Proceedings of the IEEE**, v. 63, n. 9, p. 1278–1308, 1975.

SCHNEIER, Bruce. **Secrets and Lies: Digital Security in a Networked World.** [S.l.]: Wiley, 2000.

